Remediation Roadmap

Total actions	Critical	High	Status
12	1	11	All actions open

R-006

Vulnerability management

Priority

Critical

Related control	Target date	Status
CTL-07	11/13/26	Open

Action required

Remediate or formally mitigate overdue VUL-02 and record a current target date. Verify VUL-01’s outcome against its October 20 target and address any unresolved finding. Confirm whether the Admin host is in scope; obtain scan evidence if applicable or document a justified exclusion. Reassess VUL-03 and document any renewed exception approval and compensating controls.

Evidence of completion

VUL-01 outcome verification; closure or formal mitigation records for VUL-01 and VUL-02, with updated targets where needed; a documented Admin-host scope decision supported by scan evidence or a justified exclusion; VUL-03 reassessment and any approved renewed exception with compensating controls.

Accountable owner Vulnerability Management Owner with affected system owners

Dependencies Affected system owners; vulnerability scanning coverage

R-001

Privileged access and MFA

Priority

High

Related control	Target date	Status
CTL-05	11/13/26	Open

Action required

Verify and enforce MFA for PA-010. Validate authorization and ownership for PA-010 and PA-012. Document authentication safeguards for PA-012.

Evidence of completion

MFA enforcement evidence; authorization and ownership records for PA-010 and PA-012; documented PA-012 safeguards.

Accountable owner Identity and Access Management / Privileged Access Owner

Dependencies Identity and Access Management; account owners

R-004

Terminated-user access

Priority

High

Related control	Target date	Status
CTL-04	11/13/26	Open

Action required

Immediately verify and remove access for USR-023 and USR-024 where no longer required. Reconcile termination records to active accounts and require documented follow-up for unreviewed accounts.

Evidence of completion

Account-removal or retention decisions; termination-to-account reconciliation; documented follow-up evidence.

Accountable owner Access Management with HR and relevant system owners

Dependencies HR termination data; relevant system owners

R-002

Critical vendor oversight

Priority

High

Related control	Target date	Status
CTL-03	11/27/26	Open

Action required

Obtain and review the payment processor’s current assurance report. Resolve and document incident-notification terms. Document formal risk acceptance if the terms cannot be resolved within the target period.

Evidence of completion

Current assurance report and review record; finalized incident-notification terms or approved risk acceptance.

Accountable owner Security, with Legal support for incident-notification terms

Dependencies Payment processor; Legal

R-003

Priority

CI/CD asset ownership

High

Related control	Target date	Status
CTL-02	11/27/26	Open

Action required

Assign a CI/CD platform owner, complete and document an asset review, and establish periodic review requirements for in-scope assets.

Evidence of completion

Named asset owner; completed asset-review record; periodic review standard and evidence.

Accountable owner Engineering Leadership / Designated CI/CD asset owner

Dependencies Engineering Leadership; CI/CD platform owner

R-005

Priority

Change management evidence

High

Related control	Target date	Status
CTL-06	11/27/26	Open

Action required

Require approval before normal production deployments, test evidence before closure, and documented post-implementation reviews for emergency changes. Investigate CHG-101 and CHG-103 follow-ups.

Evidence of completion

Revised workflow requirements; approval, testing, and emergency-review evidence; documented CHG-101 and CHG-103 outcomes.

Accountable owner Change Management Owner with Engineering support

Dependencies Engineering; change approvers

R-007

Logging and monitoring

Priority

High

Related control	Target date	Status
CTL-08	11/27/26	Open

Action required

Review database logging configuration, confirm support-console scope, centralize logging where required, define retention requirements, and require documented rationale and investigation notes for high-severity alert closure.

Evidence of completion

Database logging configuration; scope confirmation; retention standard; high-severity alert closure records.

Accountable owner Security Operations / Logging and Monitoring Owner

Dependencies Database and support-console owners

R-008

Incident response follow-up

Priority

High

Related control	Target date	Status
CTL-09	11/27/26	Open

Action required

Document root-cause analysis for INC-01, resolve and track TTX-01 actions, conduct and document a retest, and add specific payment-processor coordination procedures to the response plan.

Evidence of completion

INC-01 root-cause analysis; closed tabletop actions; retest record; updated response-plan procedures.

Accountable owner Incident Response Owner with Security and processor relationship owners

Dependencies Security; payment processor relationship owners

R-009

Sensitive data protection

Priority

High

Related control	Target date	Status
CTL-10	11/27/26	Open

Action required

Map the support-export data flow, validate and document analytics-store encryption at rest, define approved retention requirements, and apply and evidence retention controls for affected exports.

Evidence of completion

Data-flow map; encryption-at-rest evidence; approved retention rationale and applied export controls.

Accountable owner Data Protection Owner with Analytics and Support Operations owners

Dependencies Analytics; Support Operations

R-010

Backup and recovery

Priority

High

Related control	Target date	Status
CTL-11	11/27/26	Open

Action required

Verify backup coverage for identity configuration, define and approve recovery objectives, test restores against those objectives, and complete the missing backup-administrator access review.

Evidence of completion

Identity backup evidence; approved recovery objectives; restore-test results; completed administrator access review.

Accountable owner Backup and Disaster Recovery Owner with Identity and system owners

Dependencies Identity; critical-system owners

R-011

Payment transaction integrity

Priority

High

Related control	Target date	Status
CTL-12	11/27/26	Open

Action required

Resolve and document REC-02, document REC-03’s resolution reason, require retained independent review for payment-routing changes, and obtain technical operating evidence for transaction controls.

Evidence of completion

REC-02 and REC-03 records; routing-change independent-review evidence; technical control-operation evidence.

Accountable owner Payment Operations Owner with Change Management support

Dependencies Payment Operations; Change Management

R-012

Governance and third-party accountability

Priority

High

Related control	Target date	Status
CTL-01	11/27/26	Open

Action required

Assign one accountable owner for third-party risk, complete and document the access-policy review, and close or formally reprioritize the overdue high-priority risk committee action.

Evidence of completion

Named accountable owner; completed policy review; closed or formally reprioritized committee action with target date.

Accountable owner Director Security with assigned Third-Party Risk Owner

Dependencies Director Security; Third-Party Risk Owner

Roadmap Notes

Use this roadmap to track remediation activity. Do not mark an action complete until the listed closure evidence is available and reviewed.

Method and assumptions

1. Recommended actions, owners, and target dates are drawn from the Risk Register.

2. Priority follows the recorded inherent level. The source identifies R-006 as Critical; the remaining risks are High.

3. All actions remain Open because the Risk Register does not provide remediation-completion evidence.

4. Closure evidence and key dependencies organize the register’s remediation expectations into an execution-ready view. They do not change the recorded risk scores or residual assessment.

5. This roadmap tracks prioritized actions for the risks in the Risk Register. Additional recommendations remain in the Control Assessment Matrix. Completing these roadmap actions does not by itself establish that every control gap is closed.